Cours 1

Introduction à la Sécurité Informatique (Partie 1)

Prof. Omar Rafik Merad Boudia

rafik.merad@univ-oran1.dz

3ème année Licence (LMD) – Semestre 2

Université d'Oran 1, Ahmed Ben Bella

Année Universitaire 2025 – 2026

18 janvier 2026

Plan global de la matière

- **Introduction à la Sécurité Informatique**
  - Définitions, Principaux concepts, Objectifs de la sécurité.
  - Les menaces informatiques, Méthodes de défense, etc.
  - Risques, contexte juridique et nominatif.
- **Initiation à la Cryptographie**
  - Introduction à la Théorie des Nombres.
  - Cryptographie Classique.
  - Chiffrement Symétrique (de flux, par bloc (DES, AES).
  - Chiffrement Asymétrique (RSA, ECC).
  - Signature Numérique et Fonctions de Hachage.
  - La PKI et les Certificats Numériques.

Sommaire de ce cours

1. Introduction et Définitions
2. Concepts Fondamentaux et Objectifs
3. Les Attaques Informatiques
4. Typologie des attaques
5. Les Étapes d'une Attaque Informatique
6. Les Malwares
7. Classification des attaques réseaux
8. Le Pirate Informatique « Hacker »
9. Bibliographie

Définition de la Sécurité Informatique

Définition (SSI)

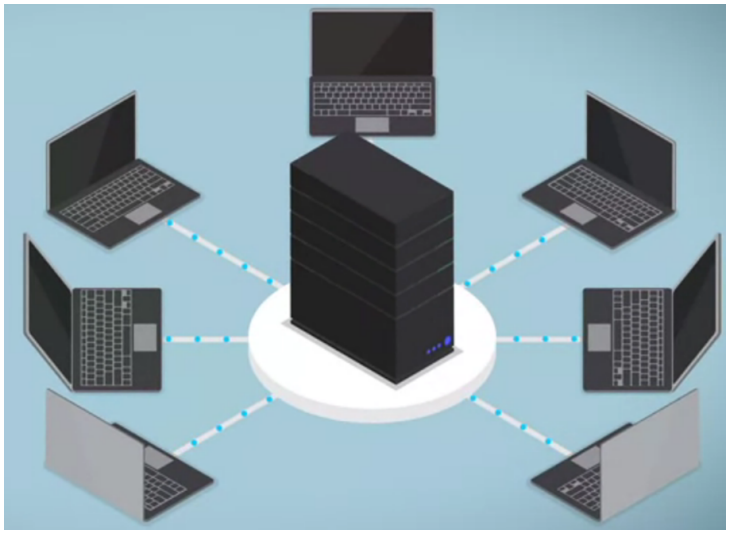
« La Sécurité Informatique ou **Sécurité des Systèmes d'Information (SSI)** est l'ensemble des moyens techniques, organisationnels, juridiques et humains nécessaires à la mise en place de moyens visant à empêcher l'utilisation non autorisée, le mauvais usage, la modification ou le détournement du système d'information » **(Source, Wikipedia)**.

Les 4 piliers de la protection :

1. **Techniques :** (Pare-feu, chiffrement).
2. **Organisationnels :** (Politiques de sécurité, audits).
3. **Juridiques :** (Lois contre la cybercriminalité, RGPD).
4. **Humains :** (Sensibilisation et formation des utilisateurs).

Qu'est-ce qu'un Système d'Information (SI) ?

- Le terme SI est générique : il désigne tout ce qui sert à faire **transiter l'information**.



Composition d'un SI

- **Matériel :** Serveurs, ordinateurs, routeurs.
- **Logiciel :** Systèmes d'exploitation, bases de données.
- **Réseau :** Protocoles de communication.
- **Humain :** Administrateurs et utilisateurs finaux.
- **Données :** L'actif le plus précieux à protéger.

La sécurité ne s'arrête pas à l'ordinateur, elle englobe tout le circuit de l'information.

Un monde interconnecté



Observation

Aujourd'hui, « Tout est connecté ». Cette hyper-connectivité multiplie la surface d'attaque.

- Les **menaces sont omniprésentes** :
  - Espionnage industriel.
  - Sabotage de services critiques.
  - Vol d'identité.

Évolution de la technologie



- Les SI sont présents **partout** : à la maison (IoT, domotique) et au travail (Cloud, serveurs).

Le principe de vulnérabilité

Important

Quel que soit le niveau de sécurité de l'équipement, il est toujours possible de le compromettre à partir du moment où l'on peut accéder à un certain niveau d'information.

Remarque :

- La sécurité absolue n'existe pas.
- On cherche à rendre l'attaque **plus coûteuse** (en temps et en argent) que la valeur de l'information ciblée.

L'affaire Jeep (2015)

Suite à une démonstration de piratage à distance (contrôle des freins et du moteur), **1,4 million de véhicules** ont dû être rappelés par le constructeur.

- **Leçon à retenir :** Aucun système, aussi perfectionné soit-il, n'est totalement protégé face aux cyberattaques.
- **Analyse :** Le passage d'un système isolé à un système connecté (via 4G/Wi-Fi) a ouvert de nouvelles vulnérabilités critiques.



Source : **ici**

Le Cloud : Définition et Fonctionnement



- **Définition :** Espaces en ligne permettant de communiquer ou d'héberger des données.
- **Principe technique :** Repose sur la **mutualisation** des ressources (calcul et stockage) distribuées dans des datacenters à travers le monde.

Imaginez le Cloud non pas comme un nuage immatériel, mais comme une usine de serveurs distants auxquels vous louez de la puissance ou de l'espace au lieu d'acheter votre propre matériel.

Le Marché du Cloud : Les Leaders

Le marché est dominé par cinq acteurs majeurs (parts de marché)[**Source**] :

1. **Amazon (AWS)** : 37.7 %
2. **Microsoft (Azure)** : 23.9 %
3. **Google Cloud** : 9 %
4. **Alibaba Cloud** : 7.2 %
5. **Huawei Cloud** : 4.1 %

Note : AWS reste le leader historique incontesté du secteur.

Usage au quotidien

Le Cloud facilite le partage de données et le fonctionnement de nombreux services modernes.

Risque

Il existe un risque permanent de **piratage** et de non-respect de la **confidentialité** des données hébergées chez un tiers.

Étude de cas : Les jouets connectés



Exemple : La poupée MyfriendCayla [Source] :

- **L'incident :** Une société de jouets a subi une fuite massive de données.
- **Conséquences :**
  - Accès à des centaines de milliers de comptes parents/enfants.
  - Interception des communications privées entre enfants et parents.

"Cet exemple illustre que la sécurité des objets connectés dépend directement de la sécurité du Cloud qui les gère."

Le Cyberespace : Un territoire sans frontières



- **Définition :** Ensemble des réseaux reliant les objets connectés entre eux.
- **Propriété :** C'est un espace **sans frontières concrètes**.
- **Impact sur la sécurité :** Les cyberattaques utilisent ce territoire pour atteindre leurs cibles, peu importe leur position géographique.

Souveraineté et Contrôle du Numérique



Face à cet espace ouvert, de nombreux pays cherchent à reprendre le contrôle :

- **Objectif :** Créer un "Internet National".
- **Moyens :** Bannir les sites non conformes aux principes du pays.
- **Nature :** Réseaux fermés respectant des normes religieuses ou idéologiques propres.

Définitions de base

Trois notions essentielles pour l'analyse de risque :

Menace (Threat) Type d'action susceptible de nuire au système.

Vulnérabilité (Faille) Niveau d'exposition ou faiblesse du système face à une menace.

Contre-mesure Actions mises en œuvre pour empêcher ou atténuer la menace.

Exemple concret

- **Menace :** Un attaquant tente d'accéder à un serveur via Internet.
- **Vulnérabilité :** Mot de passe faible ou service exposé sans protection.
- **Contre-mesure :** Pare-feu, authentification forte, mises à jour de sécurité.

Les Objectifs de la Sécurité

Pour sécuriser un système, on vise trois piliers majeurs (Le Modèle DIC) :

- **Confidentialité :** Seules les personnes autorisées accèdent à l'information.
- **Intégrité :** Les données ne doivent pas être modifiées durant leur transfert ou stockage.
- **Disponibilité :** Le système doit fonctionner sans faille et répondre aux requêtes dans les temps attendus.

Au-delà du DIC, deux concepts renforcent la confiance :

- **Authentification :** Assurer l'identité d'un utilisateur (être certain de qui est en face).
- **Non-répudiation :** Garantir qu'une transaction ou une action ne peut être niée par l'un des participants (preuve de l'envoi ou de la réception).

Les Attaques Informatiques

- Tout ordinateur connecté est potentiellement vulnérable.
- Une attaque est une exploitation d'une faille du système (OS, logiciel) ou de l'utilisateur.
- Ces attaques sont pour la plupart lancées automatiquement à partir de machines infectées (par des virus, chevaux de Troie, vers, etc.), à l'insu de leur propriétaire.
- Afin de contrer ces attaques il est indispensable de connaître les principaux types d'attaques :
  1. Accès Physique.
  2. Interception de communications.
  3. Déni de Service (DoS).
  4. Intrusion système.
  5. Ingénierie sociale (Social Engineering).
  6. Trappes ou porte dérobée (Backdoors).

Il s'agit des cas où l'attaquant possède un accès direct aux locaux ou aux machines physiques. C'est souvent la faille la plus critique (contourne les pare-feux logiciels).

- **Actions destructrices :**
  - Coupure de l'alimentation électrique.
  - Extinction manuelle brutale de l'ordinateur.
- **Vol et Espionnage :**
  - Ouverture du boîtier et vol de disque dur (données non chiffrées exposées).
  - **Sniffing physique :** Branchement d'un dispositif d'écoute directement sur le câble réseau ou le switch pour analyser le trafic.

Ces attaques visent la confidentialité et l'intégrité des données en transit sur le réseau.

- **Vol de session (Session Hijacking) :**
  - Prise de contrôle d'une session utilisateur active (souvent via le vol de cookies de session).
- **Usurpation d'identité (Spoofing) :**
  - L'attaquant se fait passer pour une entité de confiance (ex : IP Spoofing, Email Spoofing).
- **Attaque "Man-in-the-Middle" :**
  - Détournement ou altération de messages.
  - L'attaquant intercepte, lit et modifie potentiellement les données sans que les correspondants ne s'en aperçoivent.

3. Déni de Service (DoS)

C'est des attaques qui visent à rendre un service, un serveur ou un réseau indisponible pour ses utilisateurs légitimes. Il ne s'agit pas de voler des données, mais de nuire au fonctionnement.

Les deux types principaux :

Exploitation des protocoles (TCP/IP)

Utilisation des faiblesses inhérentes à la conception des protocoles réseaux.

- *Exemple :* SYN Flood (saturation des connexions).

Vulnérabilités logicielles

Exploitation de bugs dans les logiciels serveurs pour provoquer un crash.

- *Exemple :* Envoi d'une requête malformée que le serveur ne sait pas gérer.

L'intrusion consiste à pénétrer le système pour y exécuter du code ou voler des données.

- **Reconnaissance : Balayage de ports (Port Scanning)**
  - Identifier les ports ouverts (services actifs) sur une machine cible.
- **Exploitation : Élévation de privilèges**
  - Obtenir des droits d'administrateur à partir d'un accès utilisateur standard.
  - *Technique classique :* **Débordement de tampon (Buffer Overflow)**. On écrit plus de données que la mémoire ne peut en contenir pour écraser des instructions d'exécution.
- **Persistance et Charge utile : Maliciels**
  - Installation de Virus, Vers, ou Chevaux de Troie pour maintenir l'accès ou détruire des données.

5. Ingénierie sociale (Social Engineering)

C'est une technique qui ne vise pas la machine, mais l'utilisateur. C'est une pratique de manipulation psychologique.

Mécanisme :

- Exploiter la confiance, la peur, l'urgence ou la serviabilité de la victime.
- Objectif : Obtenir des informations confidentielles (mots de passe, numéros de compte) ou faire exécuter une action (ouvrir une pièce jointe).

"L'amateur attaque le système, le professionnel attaque l'administrateur."

C'est une fonctionnalité cachée (inconnue de l'utilisateur légitime) permettant un accès secret au logiciel ou au système. Elle peut être installée par un attaquant après une intrusion, ou par un développeur malveillant.

Concept clé : La sécurité est asymétrique !

La sécurisation d'un Système d'Information (SI) est dite **« asymétrique »** :

- **Défenseur :** Doit sécuriser *toutes* les vulnérabilités possibles (100% de réussite requise).
- **Attaquant :** N'a besoin de trouver qu'*une seule* faille pour réussir son intrusion.

Les 4 étapes clés d'une attaque informatique

Une attaque structurée suit généralement un processus rigoureux en quatre phases :

1. **Récupération d'informations :** Analyse de l'architecture, des systèmes et des applications.
2. **Premier accès et élévation :** Obtenir un accès initial et tenter d'étendre ses droits sur la machine.
3. **Compromission :** Phase où l'accès "administrateur" (root) est obtenu.
4. **Nettoyage des traces :** Effacer les preuves pour éviter toute détection par l'administrateur.

L'attaquant agit comme un cambrioleur : il repère d'abord les lieux, cherche une fenêtre mal fermée, s'empare des clés du coffre, puis efface ses empreintes avant de partir.

Définition : Malware

Qu'est-ce qu'un malware ?

Le terme **malware** (abréviation de *malicious software*), ou **maliciel** en français, désigne un programme développé dans le but de :

- Perturber le fonctionnement d'un système informatique.
- Détruire des logiciels ou des données.
- Compromettre la sécurité du système.

Les 6 principales catégories de malwares :

1. Les Virus informatiques
2. Les Vers (Worms)
3. Les Chevaux de Troie (Trojans)
4. Les Rootkits
5. Les Keyloggers (Enregistreurs de frappe)
6. Les Spywares (Espiogiciels)

Définition (Virus)

Un virus est un petit programme informatique situé dans le corps d'un autre programme (l'hôte). Lorsqu'on exécute l'hôte, le virus se charge en mémoire et exécute ses instructions malveillantes.

Analogie biologique

Tout comme un virus biologique a besoin d'une cellule vivante pour se multiplier, un virus informatique a besoin d'un fichier exécutable hôte pour fonctionner.

- **Classification :** Ils ne sont pas classés selon les dégâts causés, mais selon leur mode de propagation et d'infection.
- **Détection :** Les antivirus utilisent une **signature virale** (une empreinte unique du code) pour les identifier.

Typologie des Virus

Les créateurs de virus utilisent des techniques pour contourner les antivirus :

Virus Mutants

Ce sont des clones ou variantes d'un virus existant, réécrits pour modifier légèrement leur signature tout en gardant le même comportement. Cela oblige les éditeurs d'antivirus à mettre à jour leurs bases de données constamment.

Virus Polymorphes

Virus capables de modifier *automatiquement* leur apparence (signature) à chaque infection, tel un caméléon. C'est une méthode de cryptage et de modification de code dynamique.

Virus de Boot (Amorçage)

Type spécifique qui infecte le **secteur de démarrage** (Master Boot Record) d'un disque dur, s'exécutant ainsi avant même le chargement du système d'exploitation.

2. Les Vers (Worms)

Définition

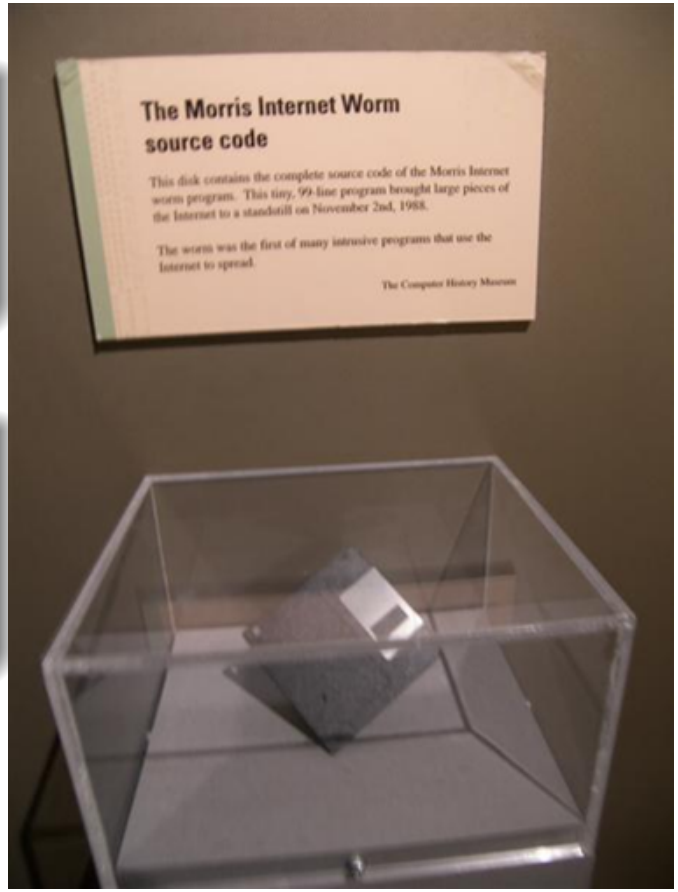
Un ver informatique est un logiciel malveillant capable de se **reproduire** sur plusieurs ordinateurs en utilisant un réseau (comme Internet).

Différence fondamentale avec le Virus

Contrairement au virus, le ver est **autonome** : il n'a pas besoin de se lier à un autre programme exécutable pour se propager. C'est un "virus réseau".

Historique :

- *Ver Morris (1988)* : premier ver célèbre.
- Création du **CERT**.



Propagation et Protection contre les Vers

Types d'infection :

- Principalement via la messagerie électronique (pièces jointes).
- Souvent sous forme de scripts (VBScript) ou d'exécutables qui s'activent au clic.

Extensions dangereuses à surveiller

Soyez vigilants avec les fichiers portant ces extensions :
`.exe`, `.com`, `.bat`, `.pif`, `.vbs`, `.scr`, `.doc`, `.xls`, `.msi`, `.eml`

Mesure de sécurité : Ne jamais ouvrir "à l'aveugle" une pièce jointe, même si l'expéditeur semble connu.

Définition (Cheval de Troie)

Logiciel en apparence légitime et inoffensif, mais qui contient une fonctionnalité malveillante cachée.

Objectifs :

- Faire entrer un parasite sur l'ordinateur à l'insu de l'utilisateur.
- Ouvrir une **porte dérobée (Backdoor)** : cela crée un accès secret permettant au pirate de contrôler la machine à distance.

Remarque *: Le nom fait référence à la ruse d'Ulysse lors du siège de Troie dans la mythologie grecque.*

Cheval de Troie : Symptômes et Défense

Mode d'infection : Ouverture d'un fichier contaminé (téléchargement, pièce jointe).

Symptômes possibles :

- Activité anormale du réseau/disque.
- Mouvements inexpliqués de la souris.
- Ouvertures soudaines de programmes.
- Plantages fréquents.

Protection :

- L'outil indispensable est le **Pare-feu**.
- Il filtre les communications entrantes et sortantes, bloquant l'accès à la porte dérobée.
- *Exemples :* ZoneAlarm, Comodo (et les pare-feux intégrés aux OS modernes).

4. Rootkit

Type de malware conçu pour maintenir un accès frauduleux (administratif) à un système tout en se dissimulant activement. Il permet au pirate d'installer d'autres outils d'attaque. *Exemples Windows : TDSS, ZeroAccess, Necurs.*

5. Keylogger (Enregistreur de frappe)

Dispositif (logiciel ou matériel) qui enregistre toutes les frappes au clavier à l'insu de l'utilisateur. C'est un outil pur d'espionnage (vol de mots de passe, conversations).

6. Spyware (Espiogiciel)

Programme chargé de collecter des informations sur l'utilisateur (habitudes de navigation, données personnelles) pour les envoyer à un tiers, souvent à des fins de **profilage** commercial ou malveillant.

Au-delà des programmes malveillants (malwares) qui infectent les machines hôtes, les **réseaux** eux-mêmes constituent une surface d'attaque critique.

Classification des attaques réseaux

On distingue généralement trois catégories principales d'attaques :

1. **Attaques de reconnaissance :**
   - Découverte et cartographie non autorisées des systèmes, services ou vulnérabilités.
2. **Attaques par accès :**
   - Manipulation non autorisée des données, des accès aux systèmes ou élévation de privilèges.
3. **Attaques par déni de service (DoS) :**
   - Désactivation, corruption ou saturation des réseaux et des services pour les rendre indisponibles.

Cette phase est cruciale pour l'attaquant : il s'agit de repérer la cible avant de frapper.

- **Identification des cibles** :
  - Utilisation d'outils publics et protocoles Internet.
  - **Outils :** `nslookup`, `whois`.
  - **Objectif :** Découvrir les plages d'adresses IP attribuées à une entreprise ou une entité.

- **Balayage et énumération** :
  - Une fois les IP connues, l'attaquant détermine quelles machines sont actives.
  - **Ping Sweep :** Envoi de requêtes ICMP (ping) pour repérer les machines en ligne.
  - **Port Scanning (ex : Nmap) :** Identification des ports ouverts (services disponibles).
  - **Sniffing (ex : Wireshark) :** Analyse des trames réseaux pour comprendre le trafic.

Remarque

Cette étape est souvent "silencieuse" ou passive, rendant sa détection difficile par les administrateurs si aucun système de détection d'intrusion (IDS) n'est en place.

L'objectif est d'obtenir un accès non autorisé à des ressources (fichiers, bases de données, comptes).

Cibles privilégiées :

- Services d'authentification.
- Services de transfert de fichiers (FTP).
- Services Web (HTTP/HTTPS).

Types d'attaque :

- **Attaques de mot de passe :** C'est l'une des méthodes les plus répandues (brute force, dictionnaire).
- Exploitation de vulnérabilités logicielles (bugs non patchés).

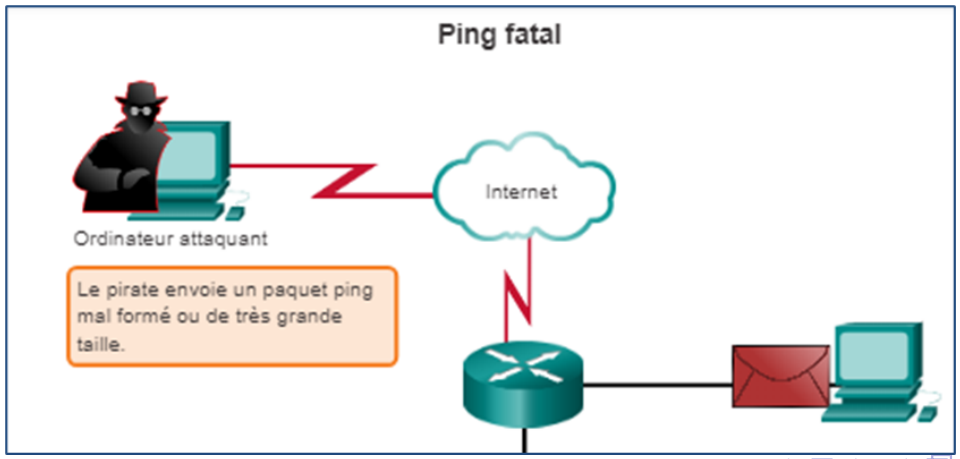
Conséquence

Une attaque par accès réussie permet à l'attaquant de consulter, modifier ou voler des données confidentielles, ou d'utiliser le système compromis comme rebond pour d'autres attaques.

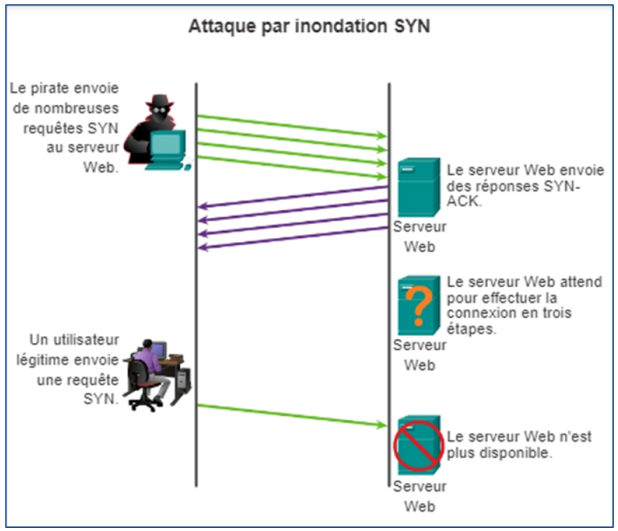
- **Concept :** Les attaques DoS (*Denial of Service*) visent à empêcher l'utilisation d'un service par les utilisateurs légitimes en épuisant les ressources du système (bande passante, processeur, mémoire).
- **Caractéristique :** Ce sont des attaques très médiatisées et souvent difficiles à éliminer complètement.

Exemple classique : Le Ping Fatal (Ping of Death)

- **Mécanisme :** L'attaquant envoie un paquet ICMP (Ping) malformé ou d'une taille supérieure à la taille maximale autorisée par le protocole IP (> 65535 octets).
- **Résultat :** Le système cible, incapable de réassembler ou gérer ce paquet aberrant, plante ou redémarre (Crash).



Le **SYN Flood** est une attaque informatique visant à atteindre un déni de service. Elle s'applique dans le cadre du protocole TCP et consiste à envoyer une succession de requêtes SYN vers la cible.



Rappel : Le "Three-Way Handshake" TCP

1. Le client envoie `SYN` (demande de connexion).
2. Le serveur répond `SYN-ACK` et alloue de la mémoire.
3. Le client répond `ACK` $\rightarrow$ La connexion est établie.

L'attaque SYN Flood

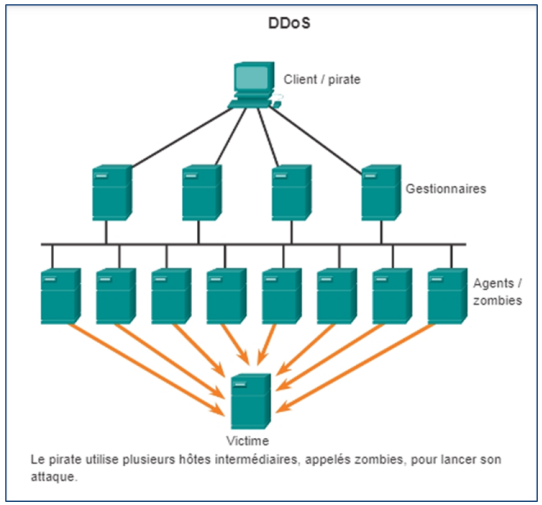
1. Le pirate envoie une rafale de requêtes `SYN`.
2. Le serveur répond `SYN-ACK` à chaque requête et attend la réponse.
3. Le pirate ne répond jamais (ou utilise une IP usurpée).
4. **Conséquence :** Le serveur maintient des connexions "semi-ouvertes" jusqu'à saturation de sa mémoire. Les clients légitimes sont rejetés.

Définition (DDoS - Distributed Denial of Service)

Attaque DoS émise simultanément depuis plusieurs sources distinctes (machines infectées).

Fonctionnement :

- L'attaquant (« Maître ») contrôle un réseau de machines compromises appelées **Zombies** ou **Botnet**.
- Sur ordre, tous les zombies attaquent la victime en même temps.



Pourquoi est-ce redoutable ?

- Le volume de trafic est gigantesque (somme des bandes passantes des zombies).
- **Difficulté de défense :** Il est extrêmement complexe de distinguer une requête malveillante d'une requête légitime, car elles proviennent de milliers d'adresses IP différentes et valides.

Qu'est-ce qu'un hacker ?

Définition historique

Le terme **« hacker »** est souvent utilisé pour désigner uniquement un pirate informatique. Son histoire montre pourtant une évolution positive à l'origine :

- **Fin des années 50 :** Désignait les experts en programmation capables d'optimiser le code de manière ingénieuse.
- **Années 70 :** Décrivait les « révolutionnaires de l'informatique » cherchant à démocratiser l'accès aux technologies.
- **Années 80 :** Apparition du sens lié au piratage, notamment pour le contournement des protections de jeux vidéo.
- **Aujourd'hui :** Terme générique pour les personnes s'introduisant dans les SI.

Remarque

Il est important de distinguer la *compétence technique* (hacking) de l'*intention* (malveillante ou éthique).

Les types de pirates : White Hats vs Black Hats

Dans le domaine de la sécurité, on classe souvent les acteurs selon leur « couleur de chapeau » (éthique) :

White Hat (Chapeau Blanc) : Hacker **éthique**. Il réalise des tests d'intrusion (pentest) et des audits pour assurer la sécurité des SI.

Black Hat (Chapeau Noir) : Hacker **mal intentionné**. Il s'introduit dans les systèmes à des fins illégales ou nuisibles.

Le Script Kiddie

Jeune utilisateur utilisant des programmes créés par d'autres (souvent trouvés sur Internet) pour détruire des SI par simple amusement, sans réelle maîtrise technique.

Spécialisations des pirates informatiques

Les pirates se spécialisent également selon leurs cibles :

- **Phreakers :** Experts s'intéressant au piratage du réseau téléphonique commuté (RTC).
- **Carders :** Spécialistes des attaques sur les systèmes de cartes à puces (bancaires, SIM, etc.).
- **Crackers :** Leur but est de casser les protections logicielles (DRM) pour distribuer des versions gratuites (piratage de logiciels).
- **Hacktivistes :** Utilisent le piratage pour porter des messages politiques ou sociétaux (ex : Anonymous).

Pourquoi pirater ? Motivations des acteurs

Les motivations varient radicalement selon le profil du hacker :

Objectifs des Black Hats :

- L'attrait de l'interdit.
- Intérêt financier (vol), politique ou étatique.
- Renommée et vengeance.
- **Envie de nuire :** détruire des données ou paralyser un système.

Objectifs des White Hats :

- L'apprentissage continu.
- Optimisation de la sécurité des SI.
- **Responsabilité :** Rendre la vulnérabilité immédiatement publique ou informer le propriétaire pour correction.

Bibliographie

- **Cybersécurité et Confidentialité**
  - *Security and Privacy in Web 3.0*, Shen, M. et al., Springer, 2024.
  - *Cybersécurité : analyser les risques, mettre en œuvre les solutions*, S. Ghernaouti, DUNOD, 2019.
- **Bases et Fondements de la Sécurité**
  - *Tout sur la sécurité informatique*, J-F. Pillou et J-P. Bay, DUNOD, 2013.
  - *Sécurité informatique et Réseaux*, S. Ghernaouti, DUNOD, 2013.
- **Gestion et Surveillance**
  - *Tableaux de bord de la sécurité réseau*, C. Llorens, L. Levier et D. Valois, Eyrolles, 2011.
- **Méthodologie et Principes**
  - *Sécurité informatique - Principes et méthodes*, L. Bloch et C. Wolfhugel, Eyrolles, 2009.
- **Ressources en ligne**
  - Site : Wikipédia – Portail de la Sécurité des Systèmes d'Information.